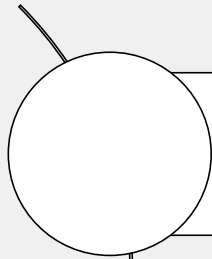
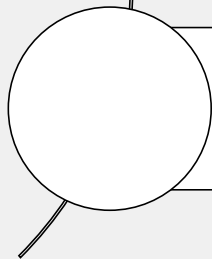


In this lesson, you will learn about firewall policies and how to apply them to allow and deny traffic passing through FortiGate. At its core, FortiGate is a firewall, so almost everything that it does to your traffic is linked to your firewall policies. You will also learn how to configure network address translation (NAT) and use it to implement source NAT (SNAT) and destination NAT (DNAT) for traffic passing through FortiGate.

Lesson Overview



Firewall Policies



NAT

In this lesson, you will learn about the topics shown on this slide.

Firewall Policies

Objectives

- Configure IPv4 firewall policies
- Monitor traffic logs from firewall policies
- Choose inspection modes for firewall policies

After completing this section, you should be able to achieve the objectives shown on this slide.

By demonstrating competence in identifying the different components of firewall policies, and recognizing how FortiGate matches traffic with firewall policies and takes appropriate action, you will have a better understanding of how firewall policies interact with network traffic.

What Are Firewall Policies?

- Policies define:
 - Which traffic matches them
 - How to process matching traffic
- When a new IP session packet arrives, FortiGate:
 - Starts at the top of the list to look for a policy match
 - Applies the first matching policy
- **Implicit Deny**
 - No matching policy?
FortiGate drops packet

Policy & Objects > Firewall Policy

Policy	ID	Source	Destination	Schedule	Service	Action	NAT	Type	Security Profiles	Log
LAN (port3) → port1										
☐ Internet_Access_ISP1 (1)	1	all	all	always	ALL	✓ ACCEPT	✓ NAT	Standard	SQL deep-inspection AV default WEB default	UTM
LAN (port3) → port2										
☐ Internet_Access_ISP2 (2)	2	all	all	always	ALL	✓ ACCEPT	✓ NAT	Standard	SQL deep-inspection AV default WEB default	UTM
☐ Implicit										
☐ Implicit Deny (0)	0	all	all	always	ALL	✗ DENY				Disabled

To begin, you will learn what firewall policies are.

Any traffic passing through a FortiGate must be associated with a firewall policy. A policy is a set of instructions that controls traffic flow through the FortiGate. These instructions determine where the traffic goes, how it's handled, and whether it's allowed to pass through the FortiGate. In summary, firewall policies are sets of rules that specify which traffic is allowed through the FortiGate and what FortiGate should do when traffic matches a policy.

Should the traffic be allowed? FortiGate bases this decision on simple criteria. FortiGate analyzes the source of the traffic, the destination IP address, and the service. If the policy does not block the traffic, FortiGate begins a more computationally expensive security profile inspection—often known as unified threat management (utm)—such as antivirus, application control, and web filtering, if you've chosen it in the policy. These inspections block the traffic if there is a security risk, for example, if the traffic contains a virus. Otherwise, the traffic is allowed.

Will NAT be applied? Is authentication required? Firewall policies also determine the answers to these questions. After processing is finished, FortiGate forwards the packet toward its destination.

FortiGate looks for the matching firewall policy from *top-to-bottom* and, if a match is found, the traffic is processed based on the firewall policy. If no match is found, the traffic is dropped by the default implicit deny firewall policy.

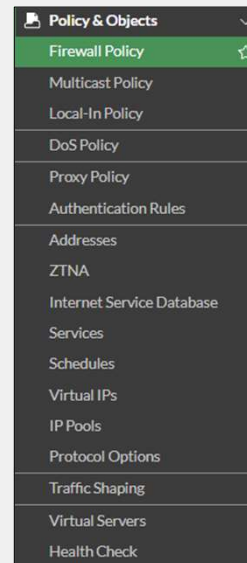
Components and Policy Types

Objects used by policies

- Interface and zone
- Address, user, and internet service objects
- Service definitions
- Schedules
- NAT rules
- Security profiles

Policy types

- Firewall Policy (IPv4, IPv6)
- Firewall Virtual Wire Pair Policy (IPv4, IPv6)
- Proxy Policy
- Multicast Policy (IPv4, IPv6)
- Local-in Policy
- DoS Policy (IPv4, IPv6)
- Traffic Shaping



Each policy matches traffic and applies security by referring to the objects that you've defined, such as addresses and profiles.

Common policy types are:

- **Firewall policy:** A firewall policy consists of set of rules that control traffic flow through FortiGate.
- **Firewall virtual wire pair policy:** A virtual wire pair policy is used to control the traffic between the interfaces in a virtual wire pair.
- **Multicast Policy:** A multicast policy allows multicast packets to pass from one interface to another.
- **Local-In Policy:** A local-in policy controls the traffic to a FortiGate interface and can be used to restrict administrative access.
- **DoS Policy:** A denial-of-service (DoS) policy checks for the anomalous patterns in the network traffic that arrives at a FortiGate interface.

By default, only **Firewall Policy** is visible under **Policy and Object**. Other policies are available based on the interface configurations and advanced features enabled through **Feature Visibility**.

In this lesson, you will learn about IPv4 firewall policies, because they are the most commonly used policies.

Configuring Firewall Policies

- Mandatory policy name when creating on GUI
 - Can relax the requirement by enabling **Allow Unnamed Policies**

- Flat GUI view allows:
 - Select by clicking
 - Drag-and-drop

```
config firewall policy
edit 1
set name "Training"
set uuid 2204966e-47f7-51..
```

Universally unique identifier (UUID)

Enabled by default
Must specify unique name

Highlights selected entry

By default, when you configure a new firewall policy using the GUI, you must specify a unique name for the policy. You will not be able to save the policy without entering something in the **Name** field. This is a best practice to help the administrators quickly identify the purposes of the policies.

By contrast, if you configure a new firewall policy using the CLI, the `name` field is optional and you are allowed to save the new policy without giving it a name. However, if you then edit that policy, the GUI requires you to add a name before you can save your changes.

You can turn off this GUI enforcement by enabling **Allow Unnamed Policies** on the **Feature Visibility** page. Enabling this feature makes the **Name** field optional on the GUI.

You can select an **Internet Service** as the source. **Internet Service** is a combination of one or more addresses and one or more services associated with a service found on the internet, such as an update service for software.

You can configure many other options in the firewall policy, such as firewall and network options, security profiles, logging options, and enabling or disabling a policy.

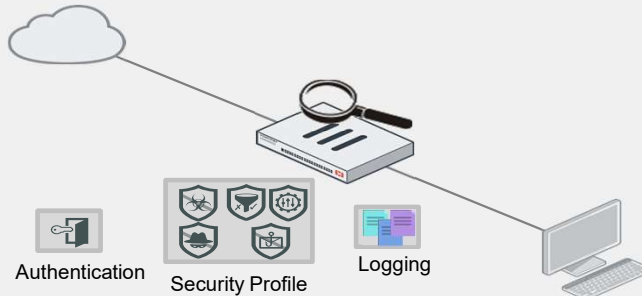
When creating firewall objects or policies, a UUID attribute is added so that logs can record these UUIDs and improve functionality when integrating with FortiManager or FortiAnalyzer.

When creating firewall policies, remember that FortiGate is a stateful firewall. As a result, you must create only one firewall policy that matches the direction of the traffic that initiates the session. FortiGate automatically remembers the source-destination pair and allows replies.

How Are Policy Matches Determined?

Incoming and outgoing interfaces	✓
Source: IP address, user, internet services	✓
Destination: IP address or internet services	✓
Services	✓
Schedules	✓

Action = **ACCEPT** or **DENY**



Policy & Objects > Firewall Policy

Name: Full Access

Schedule: always

Action: **ACCEPT** (selected) DENY

Incoming interface: port2

Outgoing interface: port4

Source & Destination: Hide logic

Source: Any of
 HQ-PC-1
 BR1-PC-1

User/group: And any of
 guest
 user1

Destination: And any of
 REMOTE_ETH2
 REMOTE_BR1_SUBNET

Service: And any of
 HTTP
 HTTPS
 DNS

When a packet arrives, how does FortiGate find a matching policy? Each policy has match criteria, which you can define using the following objects:

- **Incoming Interface**
- **Outgoing Interface**
- **Source:** IP address, user, internet services
- **Destination:** IP address or internet services
- **Schedule:** specific times to apply policy
- **Service:** IP protocol and port number

If the traffic matches a firewall policy, FortiGate applies the action configured in the firewall policy:

- If the **Action** is set to **DENY**, FortiGate drops the session.
- If the **Action** is set to **ACCEPT**, FortiGate allows the session and applies other configured settings for packet processing, such as user authentication, SNAT, antivirus scanning, web filtering, and so on.

When FortiGate receives traffic, it evaluates the packet source IP address, destination IP address, and the requested service (protocol and port number). It also checks the incoming interface and the outgoing interface it needs to use. Based on this information, FortiGate identifies the firewall policy and evaluates the traffic. If the traffic matches the policy, then FortiGate applies the action (accept/deny) defined in the policy.

For example, to block incoming FTP traffic to all but a few FTP servers, define the addresses of the FTP servers as the destination, and select FTP as the service. You probably *wouldn't* specify a source (often any location on the internet is allowed) or schedule (FTP servers are usually always available, day or night). Finally, set the **Action** setting to **ACCEPT**.

Example—Logical Operations for Firewall Policies

- Source and destination logic

Policy & Objects > Firewall Policy

Create New Policy

Source & Destination **Hide logic**

Source: Any of
 HQ-PC-1
 BR1-PC-1
 +
 And any of

User/group: guest
 user1
 +
 And any of

Destination: REMOTE_ETH2
 REMOTE_BR1_SUBNET
 +
 And any of

Service: DNS
 HTTP
 HTTPS
 +

OR operator

Show/hide logic button

Source & Destination Show logic

Source & Destination Hide logic

AND operator

Traffic must match all criteria to apply the policy

In the example shown on this slide, you can see the option to apply logical AND operations among various policy objects within the GUI.

The **Show Logic** button is available. Click **Show Logic** to display the labels **Any of** and **And any of** to clarify how the objects are used to match traffic. The **And any of** label indicates a logical AND relationship between the objects.

In the **Source & Destination** section, you will see how mandatory and optional fields interact based on the following configurations:

- Source:** Windows-Client or Mac-Clients
- User/group:** LDAP-Administrator, LDAP-Finance, or LDAP-Sales
- Destination:** Webserver1 or Webserver2
- Service:** DNS, HTTP, or HTTPS

Traffic must match all criteria above to apply the policy.

Selecting Multiple Interfaces or Any Interface

- Disabled by default
 - Cannot select multiple interfaces or any interface in firewall policy on the GUI
- Can be made visible in the GUI

Policy & Objects > Firewall Policy

Create New Policy

ID: 0

Name: Single_interface

Schedule: always

Action: ☒ ACCEPT ☐ DENY ☐ IPsec

Type: ☒ Standard ☐ ZTNA

Incoming interface: port4

Outgoing interface: port6

Multiple interface policies disabled

System > Feature Visibility

☒ Multiple Interface Policies

Allow the configuration of policies with multiple source/destination interfaces.

Policy & Objects > Firewall Policy

Create New Policy

ID: 0

Name: Multiple_interfaces

Schedule: always

Action: ☒ ACCEPT ☐ DENY ☐ IPsec

Type: ☒ Standard ☐ ZTNA

Incoming interface: port7, port8

Outgoing interface: any

Multiple interface policies enabled

By default, you can select only a single interface as the incoming interface and a single interface as the outgoing interface. This is because the option to select multiple interfaces, or **any** interface in a firewall policy, is disabled on the GUI. However, you can enable the **Multiple Interface Policies** option on the **Feature Visibility** page to disable the single interface restriction.

You can also specify multiple interfaces, or use the **any** option, if you configure a firewall policy on the CLI, regardless of the default GUI setting.

It is also worth mentioning that when you choose the **any** interface option, you cannot select multiple interfaces for that interface. In the example shown on this slide, because **any** is selected as the outgoing interface, you cannot add any additional interfaces, because **any** interface implies that all interfaces have already been selected.

Matching by Source

- **Must** specify at least one source (ISDB)
 - IP address or range
 - Subnet (IP/netmask)
 - FQDN
 - Geography
 - Dynamic
 - Fabric connector address
 - MAC address range
- **May** specify:
 - Source user—individual user or user group
 - This may refer to:
 - Local firewall accounts
 - Accounts on a remote server (for example, Active Directory, LDAP, RADIUS)
 - FSSO
 - Personal certificate (PKI-authenticated) users
- ISDB and geography are valid with a valid support contract

Mandatory source address field

Adding user is optional

Policy & Objects > Firewall Policy

Create New Policy

Name

Schedule ☒ always

Action ☒ ACCEPT ☐ DENY

Type ☒ Standard ☐ ZTNA

Incoming interface

Outgoing interface

Source & Destination

Source

User/group

Security posture tag ☐

Destination

The next match criteria that FortiGate considers is the packet's source.

In each firewall policy, you *must* select a source address object. Optionally, you can refine your definition of the source address by *also* selecting a user, or a user group, which provides a much more granular match, for increased security. You can also select ISDB objects as the source in the firewall policy, which you will learn about later in this lesson.

When selecting a FQDN as the source address, it must be resolved by DNS and cached in FortiGate. Make sure FortiGate is configured properly for DNS settings. If FortiGate is not able to resolve an FQDN address, it will present a warning message, and a firewall policy configured with that FQDN may not function properly.

FortiGate devices with valid FortiCare support contract receive up-to-date information to use the internet services database (ISDB) and geography database and use them as firewall objects.

Geographic-Based ISDB

- By default, ISDB updates are enabled
- Allows users to define ISDB objects based on a country, region, and city
- Objects can be used in firewall policies for more granular control over the location of the parent ISDB object

Policy & Objects > Internet Service Database

Edit Internet Service

Name	Training-Location-ISDB	Primary Internet Service Name	Google-Other
Type	Predefined Geographic Based	Primary Internet Service ID	65536
Primary Internet Service	Google-Other	Direction	Both
Country/Region	United States	Entries	View/Edit Entries
Region	California		
City	Sunnyvale		

Geographic-based internet service database (ISDB) objects allow users to define a country, region, and city. These objects can be used in firewall policies for more granular control over the location of the parent ISDB object.

ISDB objects are referenced in policies by name, instead of by ID.

Example—Matching Policy by Source

- Matches by source address, user
- Source as ISDB objects

Policy & Objects > Firewall Policy

ID: 0
 Name: Training
 Schedule: always
 Action: ☒ ACCEPT ☐ DENY ☐ IPsec
 Type: Standard ZTNA
 Incoming interface: LAN (port3)
 Outgoing interface: ISP1 (port1)
 Source & Destination: Hide logic
 Source: Any of LOCAL SUBNET
 Negate source: ☐
 User/group: And any of student

User

Address

Policy & Objects > Firewall Policy

ID: 0
 Name: Training
 Schedule: always
 Action: ☒ ACCEPT ☐ DENY ☐ IPsec
 Type: Standard ZTNA
 Incoming interface: LAN (port3)
 Outgoing interface: ISP1 (port1)
 Source & Destination: Hide logic
 Source: Any of Alibaba-Alibaba.Cloud Amazon-AWS
 Negate source: ☐
 User/group: And any of student

Select Entries

Search

Internet Service (1,426)

Alibaba-Alibaba.Cloud

Alibaba-Alibaba.Cloud.001

Alibaba-DNS.001

Alibaba-FTP.001

Alibaba-ICMP.001

Alibaba-Inbound_Email.001

Alibaba-LDAP.001

Alibaba-NetBIOS.Name.Service.001

Alibaba-NetBIOS.Session.Service.001

Alibaba-NTP.001

Alibaba-Other

Alibaba-Outbound_Email.001

Alibaba-RTMP.001

Alibaba-SH.001

Alibaba-Web.001

Amazon-Amazon.SES

Amazon-AWS

Amazon-AWS.001

Amazon-AWS.API.Gateway

Internet service

In the example shown on this slide, source selectors identify the specific subnet and user group. Remember, user is an optional object. The user object is used here to make the policy more specific. If you wanted the policy to match more traffic, you would leave the user object undefined.

You can also use ISDB objects as a source in the firewall policy. There is an either/or relationship between ISDB objects and source address objects in firewall policies. This means that you can select either a source address or an internet service, but not both.

Matching by Destination

Like source, destination criteria can use:

- Address objects:
 - Subnet (IP or netmask)
 - IP address or address range
 - FQDN
 - DNS query used to resolve FQDN
 - Geography
 - Country defines addresses by ISP geographical location
 - Database updated periodically through FortiGuard
 - Dynamic
 - Fabric connector address
- ISDB objects

Like the packet's source, FortiGate also checks the destination address for a match.

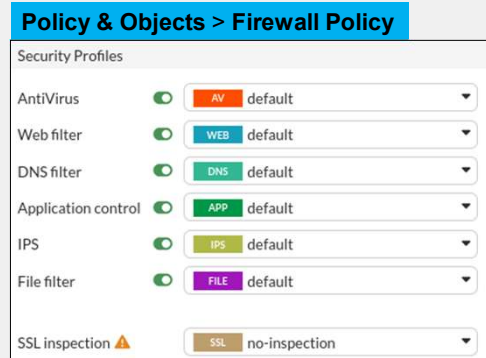
You can use address objects or ISDB objects as destinations in the firewall policy. The address object may be a host name, IP subnet, or range. If you enter an FQDN as the address object, make sure that you've configured your FortiGate device with DNS servers. FortiGate uses DNS to resolve those FQDN host names to IP addresses, that appear in the IP header.

You can also choose geographic addresses, which are groups or ranges of addresses that are assigned to a country. FortiGuard is used to update these objects.

Why is there is no option to select a user? The user identification is determined at the ingress interface, and packets are forwarded only to the egress interface after the user is successfully authenticated.

Security Profiles

- Firewall policies limit access to configured networks
- Security profiles configured in firewall policies protect your network by:
 - Blocking threats
 - Controlling access to certain applications and URLs
 - Preventing specific data from leaving your network



One of the most important features that a firewall policy can apply is security profiles, such as IPS and antivirus. A security profile inspects each packet in the traffic flow, where the session has already been conditionally accepted by the firewall policy.

When inspecting traffic, FortiGate can use one of two methods: flow-based inspection or proxy-based inspection. Different security features are supported by each inspection type.

Note that by default, the **Video Filter**, **VOIP**, **Web Application Firewall**, **Virtual Patching** and **Inline-CASB** security profile options are not visible on the policy page on the GUI. You need to enable them on the **Feature Visibility** page.

Policy ID

- Firewall policies are ordered primarily on a top-down basis
- Policy IDs are identifiers:
 - The system assigns a policy ID when the rule is created
 - The ID number never changes as rules move higher or lower in the sequence

```
config firewall policy
edit <policy_id>
end
```

Policy & Objects > Firewall Policy

Policy		ID	Source	Destination	Schedule	Service	Action	NAT
LAN (port3) → DMZ (port2) 1								
☐	DMZ (2)	2	all	all	always	ALL	✓ ACCEPT	✓ NAT
LAN (port3) → ISP 1 (port1) 2								
☐	Block FTP (1)	1	all	all	always	FTP	⊗ DENY	
☐	Full_Access (3)	3	LOCAL_SUBNET	all	always	ALL	✓ ACCEPT	✓ NAT

Policy ID

```
config firewall policy
edit 2
set name "DMZ"
...
next
edit 1
set name "Block FTP"
```

Unified policy name and ID column

An important concept to grasp about firewall policies is their reliance on order of precedence—essentially, a "first come, first served" approach.

Policy IDs are identifiers. You can add or remove the policy ID column using the **Configure Table** settings icon.

FortiGate automatically assigns a policy ID when you create a new firewall policy using the GUI. The policy ID never changes, even if you move the rule higher or lower in the sequence.

The **Policy** column on the **Policy & Objects, Firewall Policy** page combines the policy name and ID.

When you enable **Policy Advanced Options** in **Feature Visibility**, additional configuration options appear in the policy rules, including the ability to manually assign a policy ID. If you try to create a policy rule with a policy ID that already exists, the system generates an error and allows you to choose a different ID.

Assigning policy ID 0 automatically assigns the next available policy ID number, just as if you hadn't manually set it. This is useful to know when creating policy rules using the CLI, where you're required to set the policy ID and may not know the next available number.

Policy List—Interface Pair View and By Sequence

• Interface Pair View

- Lists policies by ingress and egress interfaces (or zone) pairings

Policy & Objects > Firewall Policy

Policy	ID	Source	Destination	Schedule	Service	Action	NAT	Type	Security Profiles
Block FTP (1)	1	LAN (port3)	DMZ (port2)	all	FTP	DENY	NAT	Standard	deep-inspection default, UTM
Full_Access (3)	3	LAN (port3)	ISP1 (port1)	all	ALL	ACCEPT	NAT	Standard	no-inspection, Disabled

• Sequence Grouping View and By Sequence

- If policies are created using multiple source and destination interfaces or any interface

Policy & Objects > Firewall Policy

Policy	From	To	Source	Destination	Schedule	Service	Action	IP Pool	NAT	Security Profiles
Block FTP (1)	LAN (port3)	ISP1 (port1)	all	all	allways	FTP	DENY			
DMZ (2)	LAN (port3)	DMZ (port2)	all	all	allways	ALL	ACCEPT		NAT	
Full_Access (3)	LAN (port3)	ISP1 (port1)	LOCAL_SUBNET	all	allways	ALL	ACCEPT		NAT	
Block_ICMP (4)	any	any	all	all	allways	ALL_ICMP	DENY			

FORTINET
Training Institute

© Fortinet Inc. All Rights Reserved. 16

Firewall policies appear in an organized list. The list is organized as one of **Interface Pair View**, **Sequence Grouping View**, or **By Sequence**.

By default, the policy list appears in **Interface Pair View**. Each section contains policies in the order that they are evaluated for matching traffic and are arranged by ingress-egress interface pair. Alternatively, you can view your policies as a single, comprehensive list by selecting **Sequence Grouping View** or **By Sequence** at the top of the page. In these two views, the policies are also listed in the order in which they are evaluated for traffic matching—they are grouped as uncategorized in **Sequence Grouping View** layout. You can create new labels to group firewall policies as necessary to organize the firewall policies with the sequence order in mind.

To help you remember the use of each interface, you add aliases by editing the interface on the **Network** page. For example, you could call port1 *ISP1*. This can help to make your list of policies easier to understand.

Policy List—By Sequence and Interface Pair View

Policy	From	To	Source	Destination
☐ Full_Access - ISP1 (1)	port3	port1	HQ_SUBNET	all
☐ Full_Access - ISP2 (2)	port3	port2	HQ_SUBNET	all
☐ Internal_to_WebServer (5)	port3	port4	HQ_SUBNET	all
☐ Inbound_Web_ISP1 (3)	port1	port4	all	VIP_WebServer
☐ Inbound_Web_ISP2 (4)	port2	port4	all	VIP_WebServer2
☐ Internal_to_FTPServer (6)	port3	port4	HQ_SUBNET	FTPServer
☐ Inbound_FTP_ISP1 (8)	port1	port4	all	VIP_FTPServer
☐ Inbound_FTP_ISP2 (9)	port2	port4	all	VIP_FTPServer2
☐ Internal_to_SSHTServer (7)	port3	port4	HQ_SUBNET	SSHServer
☐ Inbound_SSH_ISP1 (10)	port1	port4	all	VIP_SSHServer
☐ Inbound_SSH_ISP2 (11)	port2	port4	all	VIP_SSHServer2
☐ Implicit Deny (0)	any	any	all	all

Policy ID 1

Policy	Source	Destination
☐ port1 → port4		
☐ Inbound_Web_ISP1 (3)	all	VIP_WebServer
☐ Inbound_FTP_ISP1 (8)	all	VIP_FTPServer
☐ Inbound_SSH_ISP1 (10)	all	VIP_SSHServer
☐ port2 → port4		
☐ Inbound_Web_ISP2 (4)	all	VIP_WebServer2
☐ Inbound_FTP_ISP2 (9)	all	VIP_FTPServer2
☐ Inbound_SSH_ISP2 (11)	all	VIP_SSHServer2
☐ port3 → port1		
☐ Full_Access - ISP1 (1)	HQ_SUBNET	all
☐ port3 → port2		
☐ Full_Access - ISP2 (2)	HQ_SUBNET	all
☐ port3 → port4		
☐ Internal_to_WebServer (5)	HQ_SUBNET	WebServer
☐ Internal_to_FTPServer (6)	HQ_SUBNET	FTPServer
☐ Internal_to_SSHTServer (7)	HQ_SUBNET	SSHServer
☐ Implicit		
☐ Implicit Deny (0)	all	all

While the default view for the policy list is **Interface Pair View**, it is essential to approach firewall policies as a complete list. Place specific policies at the top, followed by more general policies. This concept applies in both **Interface Pair View** and **By Sequence**, emphasizing the importance of viewing it as a single, ordered list. The firewall begins evaluating policies from the top of the list, so organize them with the most specific and more heavily used rules at the top.

Adjusting Policy Order

- On the GUI, drag and drop

Before policy move

+ Create new Policy match Search				
Policy	ID	From	To	S
☐ Full_Access (1)	1	LAN (port3) DMZ (port2)	ISP1 (port1)	
☐ Block_FTP (2)	2	LAN (port3)	ISP1 (port1)	
☐ DMZ (3)	3	LAN (port3)	DMZ (port2)	

```
config firewall policy
  edit 1
    set name "Full_Access"
    ...
  next
  edit 2
    set name "Block_FTP"
```

After policy move

+ Create new Policy match Search				
Policy	ID	From	To	S
☐ Block_FTP (2)	2	LAN (port3)	ISP1 (port1)	
☐ Full_Access (1)	1	LAN (port3) DMZ (port2)	ISP1 (port1)	
☐ DMZ (3)	3	LAN (port3)	DMZ (port2)	

ID remains same

```
config firewall policy
  edit 2
    set name "Block_FTP"
    ...
  next
  edit 1
    set name "Full_Access"
```

Remember you learned that only the first matching policy applies? Arranging your policies in the *correct position* is important. It affects which traffic is blocked or allowed. In the section of the applicable interface pair, FortiGate looks for a matching policy, beginning at the top. So, you should put more specific policies at the top; otherwise, more general policies will match the traffic first, and more granular policies will never be applied.

In the example shown on this slide, you're moving the **Block_FTP** policy (ID 2) that matches only FTP traffic, to a position above a more general **Full_Access** (accept everything from everywhere) policy. Otherwise, FortiGate would always apply the first matching policy in the applicable interface pairs—**Full_Access**—and never reach the **Block_FTP** policy.

When moving the policies across the policy list, policy IDs remain unchanged.

Moving Policies by ID

- On the GUI, move by ID

Before policy move

Policy	ID	From	To	Source
☐ Full_Access (1)	1	ISP1 (port1)	LAN (port3)	all
☐ Deny (4)	4	ISP1 (port1)	LAN (port3)	Deny_IP
☐ 5	5	ISP1 (port1)	LAN (port3)	REMOTE_ETH1
☐ 6	6	ISP1 (port1)	LAN (port3)	LOCAL_SUBNET
☒ Allow_Access (3)	3	ISP1 (port1)	LAN (port3)	all
☐ Implicit Deny (0)	0	any	any	all

Unified policy name and ID column

Move by ID

After policy move

Policy	ID	From	To	Source
☐ Full_Access (1)	1	LAN (port3)	ISP1 (port1)	all
☐ Deny (4)	4	ISP1 (port1)	LAN (port3)	Deny_IP
☒ Allow_Access (3)	3	ISP1 (port1)	LAN (port3)	all
☐ 5	5	ISP1 (port1)	LAN (port3)	REMOTE_ETH1
☐ 6	6	ISP1 (port1)	LAN (port3)	LOCAL_SUBNET
☐ Implicit Deny (0)	0	any	any	all

Move by ID

Selected policy: Allow_Access (3)

Move: ☐ Above ☒ Below

Destination policy ID: 4

Jump to policy after move: ☒

Move the policy above or below the specified policy ID

You can move policies by their ID, placing them before or after a specified policy ID.

Using **Move by ID** is especially useful when you have hundreds of policies, because dragging and dropping would take too much time. Moving by ID allows you to quickly organize policies without manually dragging them.

If you do not want to automatically view the new location of the policy, disable **Jump to policy after move**. This feature is enabled by default.

You can only move policies by ID when viewing the **Firewall Policy** page in **By Sequence** or **Sequence Grouping View**.

Combining Firewall Policies

- Check the settings before combining firewall policies
 - Source and destination interfaces
 - Source and destination addresses
 - Services
 - Schedules
 - Security profiles
 - Logging
 - NAT rules

Policy & Objects > Firewall Policy

Policy	ID	Source	Destination	Schedule	Service	Action	NAT	Type	Security Profiles	Log	Bytes
Full_Access (1)	1	all	all	always	Web Access FTP	✓ ACCEPT	✓ NAT	Standard	SSL deep-inspection AV default WEB default	UTM	298.24 kB
ICMP (2)	2	all	all	always	ALL_ICMP	✓ ACCEPT	✓ NAT	Standard	SSL no-inspection	All	74.92 kB
Implicit											
Implicit Deny (0)	0	all	all	always	ALL	✗ DENY				✗ Disabled	917.89 kB

Can combine Policy ID 1 and 2 by combining services

Make decisions for logging settings when combining Policy ID 1 and 2

In order to optimize and consolidate firewall policies, always check all configured settings. In the example shown on this slide, the two firewall policies have differences in terms of services, security profiles, and logging settings. You can consolidate these two firewall policies by combining services and choosing appropriate logging settings.

If you select **Security Events** (UTM) for the logging settings, traffic logs will not be generated for **ALL_ICMP** traffic.

Note that the **ALL_ICMP** service is not subject to web filter and antivirus scans, which means that applying these security profiles to the ICMP traffic will result in the traffic passing through without being inspected.

Best Practices

- Test policies in a maintenance window before deploying in production
 - Test policy for a few IP addresses, users, and so on
- Be careful when editing, disabling, or deleting firewall policies and objects
 - Changes are saved and activated immediately
 - Reevaluate active sessions
- Create firewall policies to match as specifically as possible
 - Example: Restrict firewall policies based on source, destination, service
 - Use proper subnetting for address objects
- Analyze and enable appropriate settings on a per-policy basis
 - Security profiles
 - Logging settings

Always plan a maintenance window and create a test case for a few IP addresses and users, before implementing configuration changes in the production network. Any configuration changes made using the GUI or CLI take effect immediately, and can interrupt service.

As a best practice, try to configure firewall policies as specifically as possible. This helps to restrict access to only those resources. For example, use correct subnets when configuring address objects.

Another setting worth mentioning is security profiles. Security profiles help to provide appropriate security for your network. Proper logging configuration can also help you to analyze, diagnose, and resolve common network issues.

Inspection Modes on Firewall Policies

- Enabling security profiles has an impact on firewall throughput
- FortiGate kernel inspect sessions to enforce filtering (for example, web filter)
- Selecting the FortiGate inspection modes on firewall policies:
 - Flow-based
 - Default mode
 - Optimizes performance
 - Proxy-based
 - Processed by CPU
 - Provides thorough inspection

Policy & Objects > Firewall Policy

Name: Training

Schedule: always

Action: ☒ ACCEPT ☐ DENY ☐ IPsec

Type: Standard ZTNA

Incoming interface: LAN (port3)

Outgoing interface: ISP1 (port1)

Source & Destination Show logic

Source: all

Negate source: ☐

User/group:

Security posture tag: ☐

Destination: all

Negate destination: ☐

Service: ALL

Firewall/Network Options

Inspection mode: ☒ Flow-based ☐ Proxy-based

Enabling the security profiles on FortiGate impacts firewall resources and throughput. Packets are sent to the kernel or main CPU to enforce filtering. FortiOS supports flow-based and proxy-based inspection in firewall policies and security profiles.

Depending on your requirements, you can select inspection mode, but it is useful to know some differences and how it can impact the firewall performance. Flow-based inspection identifies and blocks threats in real time as FortiOS identifies them. This requires lower processing resources than proxy-based inspection. It is recommended to apply flow-based inspection to policies that prioritize traffic throughput.

Proxy-based inspection involves buffering traffic and examining it as a whole, before determining an action. Having all the data to analyze allows for the examination of more data points than flow-based inspection. Some advanced features like usage quota and web-profile override are also supported in proxy-based inspection.

Inspection Modes—Proxy-Based Visibility

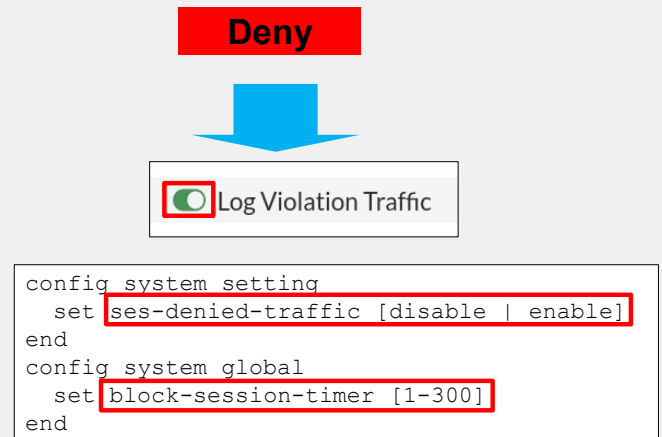
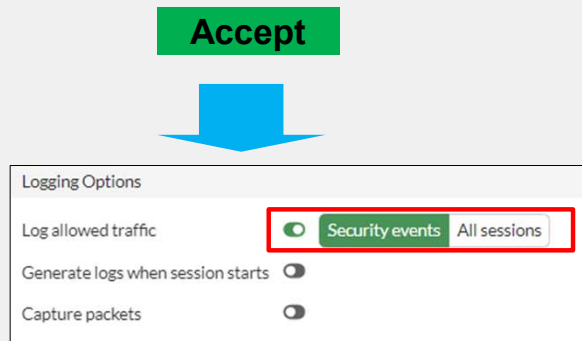
- Proxy-based inspection mode is available on most FortiGate devices
- Some security profiles are available only in proxy-based inspection mode, such as:
 - Video Filter
 - Inline CASB
 - ICAP
 - Web Application Firewall
 - Data Leak Prevention (available on the CLI)
- Proxy-based inspection is not available on low-end platforms with 2 GB of RAM or less

By default, low-end FortiGate platforms with 2 GB or less of RAM do not show proxy-based settings on the GUI for firewall policies and security profiles. This is to reduce memory usage on these platforms because the RAM is designed to serve the purpose of the low-end FortiGate and also maximize security using flow-based security inspection across FortiGate.

To confirm whether your FortiGate supports proxy inspection, enter `diagnose hardware sysinfo conserve` on the CLI. If the total RAM value is less than 2 GB, then your device has 2 GB RAM or less.

Logging

- By default, set to **Security Events**
 - Generates logs based on applied security profile only
- Can change to **All Sessions**



If you have enabled logging in the policy, FortiGate generates traffic logs after a firewall policy closes an IP session.

By default, **Log Allowed Traffic** is enabled and set to **Security Events** and generates logs only for the applied security profiles in the firewall policy. However, you can change the setting to **All Sessions**, which generates logs for all sessions.

If you enable **Generate Logs when Session Starts**, FortiGate creates a traffic log when the session begins. FortiGate also generates a second log for the same session when it is closed. But remember that increasing logging decreases performance, so use it only when necessary.

During the session, if a security profile detects a violation, FortiGate records the attack log immediately. To reduce the number of log messages generated and improve performance, you can enable a session table entry of dropped traffic. This creates the denied session in the session table and, if the session is denied, all packets of that session are also denied. This ensures that FortiGate does not have to perform a policy lookup for each new packet matching the denied session, which reduces CPU usage and log generation.

The CLI command is `ses-denied-traffic`. You can also set the duration for block sessions. This determines how long a session will be kept in the session table by setting `block-session-timer` in the CLI. By default, it is set to 30 seconds.

If the GUI option **Generate Logs when Session Starts** is not displayed, this means that your FortiGate device does not have internal storage. Regardless of internal storage, the CLI command is `set logtraffic-start enable`.

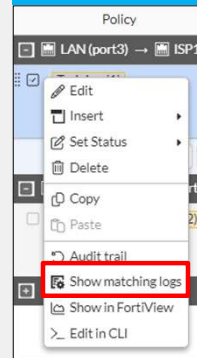
Monitor Traffic Logs

- FortiGate supports storing all types of logs in several log devices
 - FortiGate local and cloud
 - FortiAnalyzer local and cloud
 - Syslog
- View traffic logs in **Log & Report > Forward Traffic**
 - Apply filter to display relevant logs
 - Select the source of logs
 - Specify the historical time frame
- Right-click firewall policy and view matching traffic logs

Log & Report > Forward Traffic

Date/Time	#	Source	Device	Destination	Application name	Result	Policy ID
2024/10/01 15:14:34		100.1.1.10	02:09:00:00:01:01	8.8.8.8	DNS	✓ Accept (842 B / 926 B)	Training (1)
2024/10/01 15:14:28		100.1.1.10	02:09:00:00:01:01	8.8.8.8	DNS	✓ Accept (342 B / 500 B)	Training (1)
2024/10/01 15:14:28		100.1.1.10	02:09:00:00:01:01	74.32.190.33	tcp/8080	✓ Accept (117.15 KB / 29.63 MB)	Training (1)
2024/10/01 15:14:28		100.1.1.10	02:09:00:00:01:01	74.32.190.33	tcp/8080	✓ Accept (105.51 KB / 29.19 MB)	Training (1)
2024/10/01 15:14:28		100.1.1.10	02:09:00:00:01:01	64.79.50.98	tcp/8080	✓ Accept (127.83 KB / 30.39 MB)	Training (1)
2024/10/01 15:14:28		100.1.1.10	02:09:00:00:01:01	64.79.50.98	tcp/8080	✓ Accept (112.03 KB / 28.45 MB)	Training (1)
2024/10/01 15:14:28		100.1.1.10	02:09:00:00:01:01	64.79.50.98	tcp/8080	✓ Accept (114.13 KB / 28.52 MB)	Training (1)

Policy & Objects > Firewall Policy



Apply the desired filter to reduce irrelevant log entries

Only logs matching the firewall policy are displayed on the forward traffic logs page

Logging on FortiGate records the traffic that passes through, starts from, or ends on FortiGate. It records the actions during the traffic scanning process. FortiGate supports sending all log types to several log devices including its local storage, which is subject to the disk available on different FortiGate models.

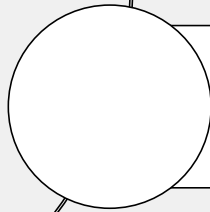
You can view traffic logs in **Log & Report > Forward Traffic**. Apply the filter needed to display the logs and then enter the policy UUID in the filter field to display records that match the firewall policy. Select the source of the logs and specify the historical time frame to reduce irrelevant log entries.

You can also view the logs by right-clicking the firewall policy, and then clicking **Show matching logs**.

Lesson Progress



Firewall Policies



NAT

Good job! You now understand firewall policies.

Now, you will learn about NAT.

NAT

Objectives

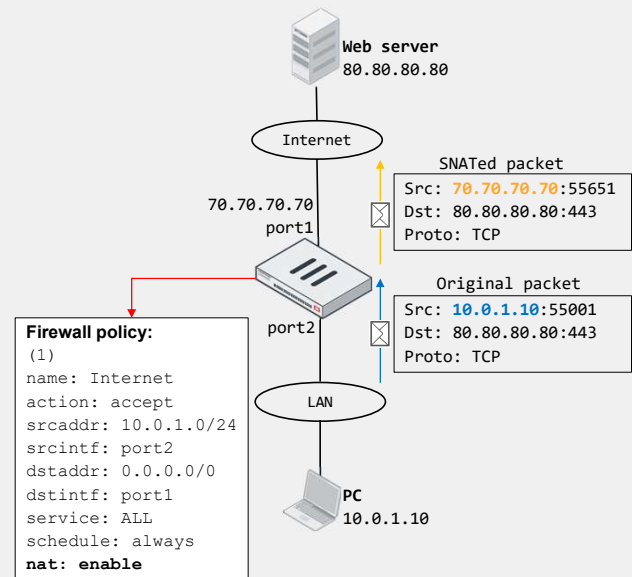
- Configure SNAT
- Configure a firewall policy to perform DNAT using VIP

After completing this section, you should be able to achieve the objectives shown on this slide.

By demonstrating competence in NAT firewall policies, you will be able to configure firewall policies, invoke SNAT and DNAT on the policies, and understand how the policies are applied to traffic traversing FortiGate.

NAT

- Method of translating IP addresses in a packet
 - If ports are also translated, it is called PAT
- Benefits:
 - Real address is hidden from external networks
 - Prevents depletion of public IP address space
 - Private address space flexibility
- Types:
 - SNAT
 - Translates source IP address and source port
 - Enabled on firewall policy
 - DNAT
 - Translates destination IP address and destination port
 - Requires VIP object on firewall policy



NAT is a method that enables a NAT device such as a firewall or router, to translate (or map) the IP address in a packet to another IP address, usually for connectivity purposes. If the port information in the packet is also translated, then the translation method is called PAT. NAT provides the following benefits:

- Security: The real address of a device is hidden from external networks.
- Public address depletion prevention: Hundreds of computers can share the same public IPv4 address.
- Private address flexibility: The addresses can stay the same, even if ISPs change. You can reuse private addresses in multiple networks.

There are two types of NAT: SNAT and DNAT. In SNAT, a NAT device translates the source IP address and source port in a packet. In DNAT, a NAT device translates the destination IP address and destination port.

You can configure FortiGate to perform SNAT and DNAT as follows:

- For SNAT, you enable NAT on the matching firewall policy.
- For DNAT, you configure virtual IPs (VIPs) and then reference them on the matching firewall policy.

The example on this slide shows the most common use case for NAT: SNAT. FortiGate, acting as a NAT device, translates the private IP address assigned to the PC to the public address assigned by your ISP. The private-to-public source address translation is needed for the PC to access the internet web server.

Firewall Policy SNAT

- There are two ways to SNAT traffic:
 - Using the outgoing interface address
 - Using a dynamic IP pool

Policy & Objects > Firewall Policy

Name ^① Training

Schedule always

Action ☒ ACCEPT ☐ DENY ☐ IPsec

Type Standard ZTNA

Incoming interface LAN (port3)

Outgoing interface ISP1 (port1)

Source & Destination Show logic

Source LOCAL_SUBNET

Negate source ☐

User/group

Security posture tag ☐

Destination all

Negate destination ☐

Service ALL

Firewall/Network Options

Inspection mode ☒ Flow-based ☐ Proxy-based

NAT ☒ NAT NAT46 NAT64

IP pool configuration ☒ Use Outgoing Interface Address ☐ Use Dynamic IP Pool

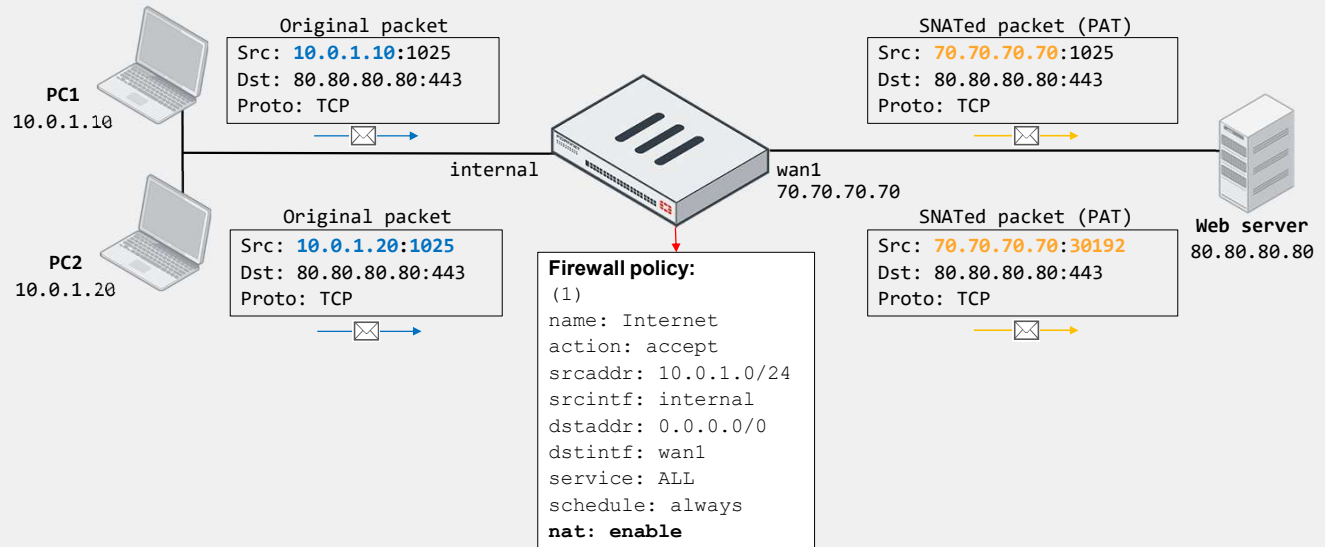
Preserve source port ☐

Protocol options ☒ PROXY default

To configure a firewall policy, you can enable SNAT in the firewall and network options section. There are two options to select and choose how SNAT should work:

1. To use the outgoing interface IP address: Packets matching the firewall policy translate the IP address in a packet to another IP address, usually for connectivity purposes.
2. To use a dynamic IP pool: This is dynamic SNAT which allows FortiGate to map private IP addresses to the first available public address from a pool of addresses.

Firewall Policy SNAT Using the Outgoing Interface



When you select **Use Outgoing Interface Address** on the matching firewall policy, FortiGate uses the egress interface address as the NAT IP for performing SNAT.

If there are multiple devices behind FortiGate, FortiGate performs many-to-one NAT. This is also known as PAT. FortiGate assigns to each connection sharing the egress interface address a port number from a pool of available ports. The assignment of a port enables FortiGate to identify packets associated with the connection and then perform the corresponding translation. This is the same behavior as the overload IP pool type, which you will also learn about.

Optionally, you may select a fixed port, in which case the source port translation is disabled. With a fixed port, if two or more connections require the same source port for a single IP address, only one connection is established.

The example on this slide shows two PCs behind FortiGate that share the same public IP address (70.70.70.70) to access the internet web server 80.80.80.80. Because **Use Outgoing Interface Address** is enabled on the firewall policy—`set nat enable` on the CLI—the source IP address of the PCs is translated to the egress interface address. The source port, however, is not always translated. It depends on the available ports and the connection 5-tuple. In the example shown on this slide, FortiGate translates the source port of the connection from PC2 only. Otherwise, the two connections would have the same information on the session table for the reply traffic, which would result in a session clash.

IP Pools

- IP pools define a single IP address or a range of IP addresses to be used as the source address for the duration of the session
- IP pools are usually configured in the same range as the interface IP address
- There are four types of IP pools:
 - Overload (default)
 - One-to-one
 - Fixed port range
 - Port block allocation

Useful for CGN

Policy & Objects > IP Pools

New Dynamic IP Pool

Name

Comments 0/255

Type **Overload**

External IP Range

NAT64 ☐

ARP Reply ☐

Policy & Objects > Firewall Policy

Name Training

Schedule always

Action ☒ ACCEPT ☐ DENY ☐ IPsec

Type ☒ Standard ☐ ZTNA

Incoming interface LAN (port3)

Outgoing interface ISP1 (port1)

Firewall/Network Options

Inspection mode ☒ Flow-based ☐ Proxy-based

NAT ☒ NAT ☐ NAT46 ☐ NAT64

IP pool configuration ☒ Use Outgoing Interface Address ☒ Use Dynamic IP Pool

☒ INTERNAL-HOST-EXT-IP

IP pools allow sessions leaving the FortiGate firewall to use NAT. An IP pool defines a single IP address or a range of IP addresses to be used as the source address for the duration of the session. These assigned addresses are used instead of the IP address assigned to that FortiGate interface.

IP pools are usually configured in the same range as the interface IP address.

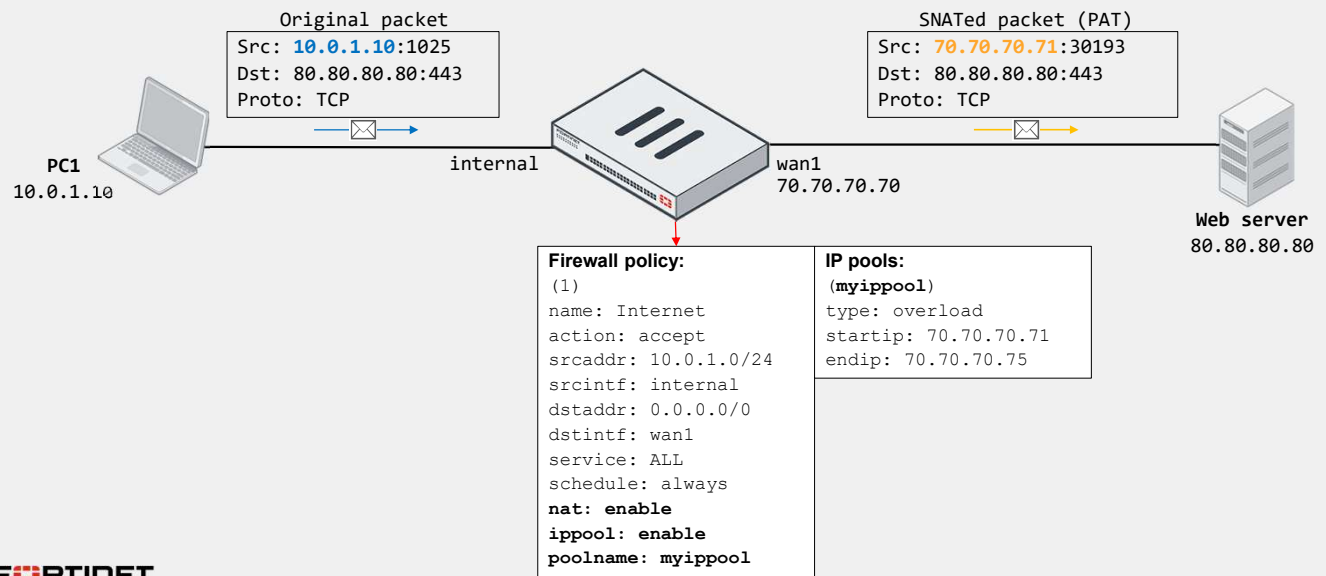
When you configure the IP pools that will be used for NAT, there is a limitation that you must take into account. If the IP addresses in the IP pool are different from the IP addresses that are assigned to the interfaces, communications based on those IP addresses *may fail if the routing is not properly configured*. For example, if the IP address assigned to an interface is 172.16.100.1/24, you cannot choose 10.10.10.1 to 10.10.10.50 for the IP pool unless you configure appropriate routing.

There are four types of IP pools that you can configure on the FortiGate firewall:

- Overload
- One-to-one
- Fixed port range
- Port block allocation

The fixed port range and port block allocation types are more common carrier-grade NAT (CGN) deployments.

IP Pool Type—Overload



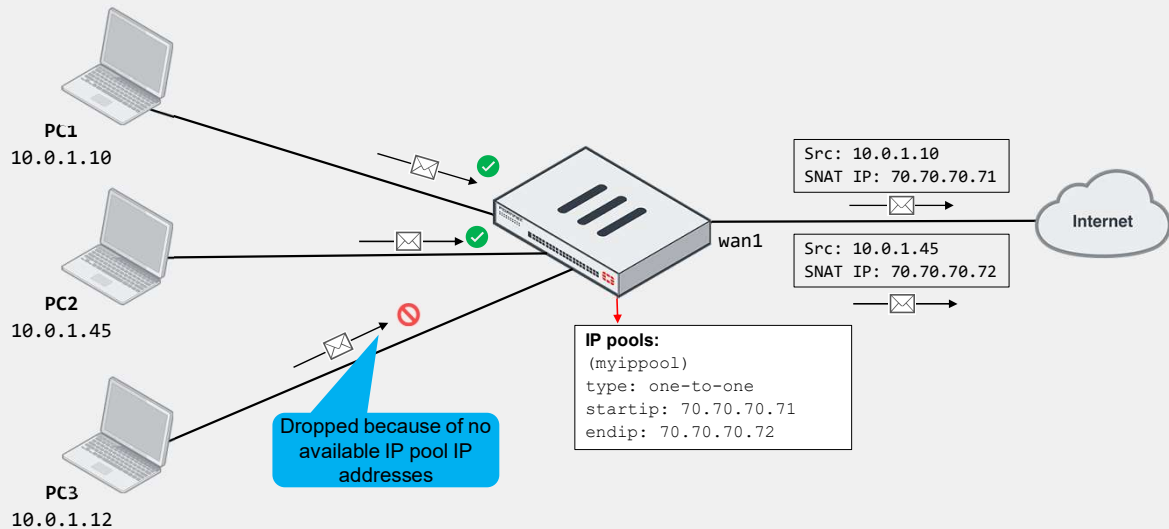
If you use an IP pool, the source address is translated to an address from that pool, rather than the egress interface address. The larger the number of addresses in the pool, the greater the number of connections that the pool can support.

The default IP pool type is overload. In the overload IP pool type, a many-to-one or many-to-few relationship and port translation is used.

In the example shown on this slide, source IP 10.0.1.10 is translated to the address 70.70.70.71, which is one of the addresses defined in the IP pool (70.70.70.71 – 70.70.70.75).

IP Pool Type—One-to-One

- Assigns an IP pool address to an internal host on a first-come, first-served basis
 - Packets from unserved hosts are dropped if there are no available addresses in the IP pool



In the one-to-one pool type, FortiGate assigns an IP pool address to an internal host on a first-come, first-served basis.

There is a single mapping of an internal address to an external address. That is, an IP pool address is not shared with any other internal host, thus the name one-to-one. If there are no more addresses available in the IP pool, FortiGate drops packets from unserved hosts.

The example on this slide shows three internal hosts accessing the internet. PC1 and PC2 packets are received first by FortiGate and, therefore, assigned addresses 70.70.70.71 and 70.70.70.72, respectively. However, FortiGate drops packets sourced from PC3 because they arrived last, which is when there are no more available addresses in the IP pool to choose from.

VIPs

- DNAT objects
- Default type is **Static NAT**
 - One-to-one mapping, applies to both:
 - Ingress traffic (DNAT; use internal IP as NAT IP)
 - Egress traffic (SNAT; use external IP as NAT IP)
 - Reference IP addresses or FQDN objects (set **Type** to **FQDN**)
- Enable **Port Forwarding** to:
 - Redirect traffic destined to external IP and port to mapped internal address and port
 - Reuse external IP on multiple VIPs

Policy & Objects > Virtual IPs

New Virtual IP

Name: VIP-INTERNAL-HOST

Comments: Write a comment... 0/255

Color: Change

Network

Interface: ISP1 (port1)

Type: Static NAT FQDN

External IP address/range: 100.64.100.22

Map to:

IPv4 address/range: 10.0.1.10

IPv6 address/range: Starting IPv6 address

Optional Filters

Port Forwarding

Policy & Objects > Firewall Policy

Edit Policy

ID: 2

Name: Web Server Access

Schedule: always

Action: ACCEPT DENY IPsec

Type: Standard NAT

Incoming interface: ISP1 (port1)

Outgoing interface: LAN (port3)

Source & Destination

Source: Any

Destination: VIP-INTERNAL-HOST

Service: HTTP HTTPS

Firewall/Network Options

Inspection mode: Flow-based Proxy-based

NAT: NAT NAT44 NAT64

IP pool configuration: Use Outgoing Interface Address Use Dynamic IP Pool

Preserve source port: ☒

Protocol options: default

VIP used as destination in firewall policy

VIPs are DNAT objects. For sessions matching a VIP, the destination address is translated; usually a public internet address is translated to the private network address of a server. VIPs are selected in the firewall policy **Destination** field.

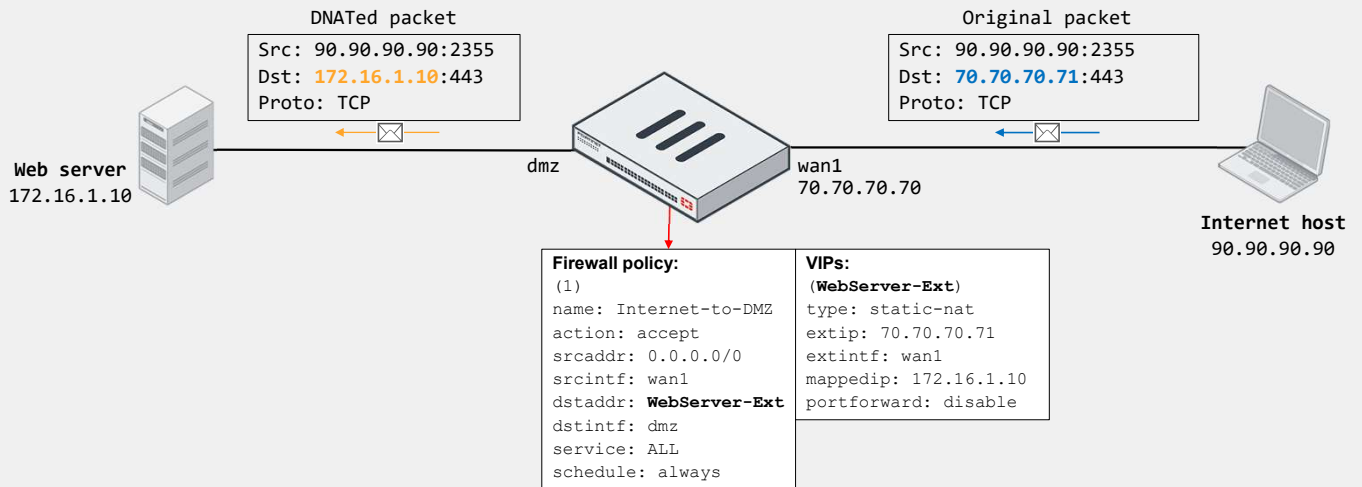
The default VIP type is **Static NAT**. This is a one-to-one mapping. This means that:

1. FortiGate performs DNAT on ingress traffic destined to the external IP address defined in the VIP, regardless of the protocol and port of the connection, provided the matching firewall policy references the VIP as **Destination**.
2. FortiGate uses the external IP address defined in the VIP as the NAT IP address when performing SNAT on all egress traffic sourced from the mapped address in the VIP, provided the matching firewall policy has NAT enabled. That is, FortiGate doesn't use the egress interface address as NAT IP.

Note that you can override the behavior described in step 2 by using an IP pool. You can also select **FQDN** as the VIP type. When you select **FQDN**, you can configure FQDN address objects as external and internal IP addresses. This enables FortiGate to automatically update the external and internal IP addresses used by the VIP in case the FQDN resolved address change.

Optionally, you can enable **Port Forwarding** on the VIP to instruct FortiGate to redirect the traffic matching the external address and port in the VIP to the mapped internal address and port. When you enable port forwarding, FortiGate no longer performs one-to-one mapping. This means that you can reuse the same external address and map it to different internal addresses and ports provided the external port is unique. For example, you can configure a VIP so connections to the external IP address 70.70.70.70 on port 8080 map to the internal IP address 192.168.0.70 on port 80. You can then configure another VIP so connections to the external IP address 70.70.70.70 on port 8081 map to the internal IP 192.168.0.71 on port 80.

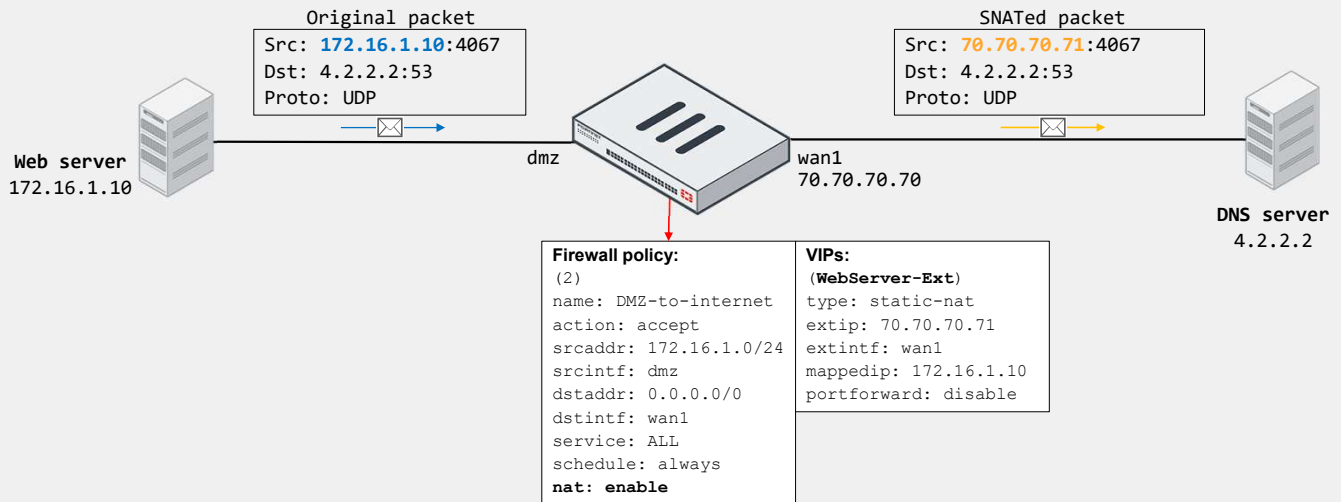
VIP Example—Static NAT—Incoming Connection



In the example shown on this slide, the internet host initiates a connection to 70.70.70.71 on TCP port 443. On FortiGate, the traffic matches the firewall policy ID 1, which references the WebServer-Ext VIP as destination. Because the VIP is configured as static NAT and has port forwarding disabled, then FortiGate translates the destination address of the packet to 172.16.1.10 from 70.70.70.71. Note that the destination port doesn't change because port forwarding is disabled.

Also note that the external interface address is different from the external address configured in the VIP. This is not a problem as long as the upstream network has its routing properly set. You can also enable ARP reply on the VIP (enabled by default) to facilitate routing on the upstream network. You will learn more about ARP reply in this lesson.

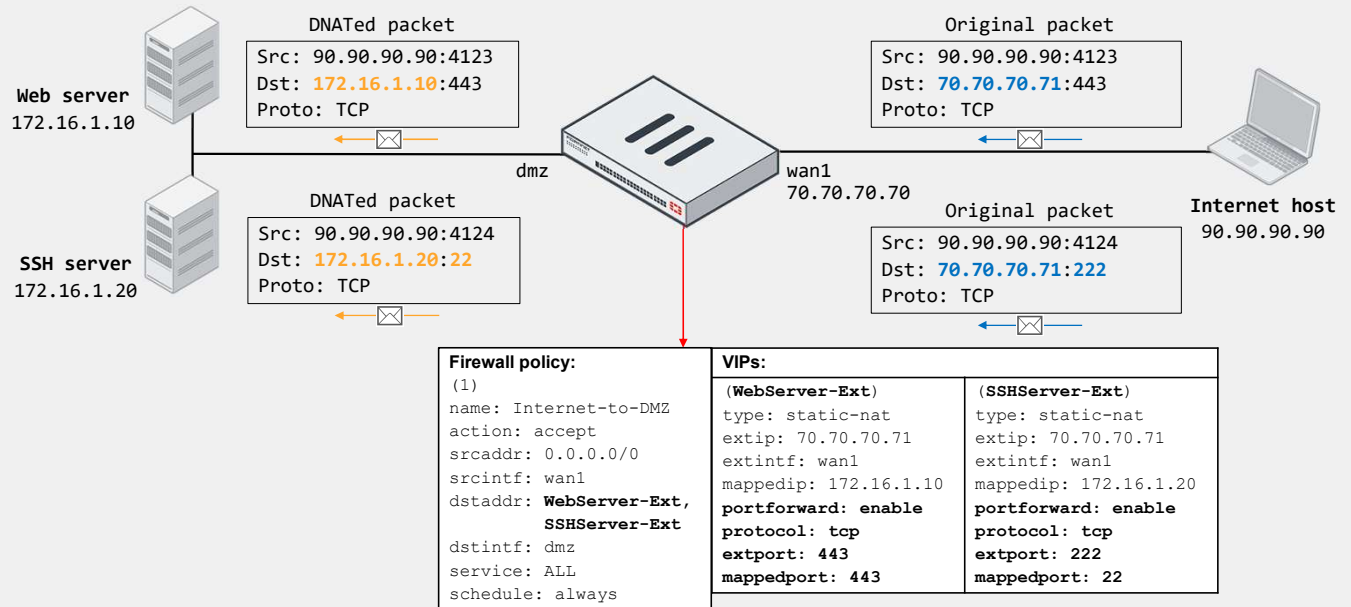
VIP Example—Static NAT—Outgoing Connection



Now, suppose that the internal web server (172.16.1.10) initiates a DNS connection to the internet DNS server (4.2.2.2). On FortiGate, the traffic matches the firewall policy ID 2, which has `nat` enabled. Because the source address matches the internal address of the VIP, and because the VIP is configured as static NAT with port forwarding disabled, FortiGate translates the source address of the packet to 70.70.70.71 from 172.16.1.10. Note that FortiGate doesn't have to perform PAT because the static NAT VIP equals one-to-one mapping. That is, the external IP is used by the web server only for SNAT.

Also note that FortiGate uses the VIP external address for SNAT if the VIP is referenced in an incoming firewall policy. That is, if you don't configure firewall policy ID 1, which is shown on the previous slide, or if you disable the firewall policy, then FortiGate doesn't automatically use the external IP for translating the source address of the web server. Instead, FortiGate uses the egress interface address (70.70.70.70).

VIP Example—Port Forwarding—Incoming Connection



The example on this slide shows how FortiGate handles two incoming connections to the same external address, but on different ports. FortiGate forwards each connection to a different internal host based on the VIP mapping settings. This is possible because port forwarding is enabled on the VIPs, which enables FortiGate to redirect the external traffic to the corresponding internal address and port, while using the same external address.

Both connections match the firewall policy ID, which references two VIPs as destination. The HTTPS connection matches the `WebServer-Ext` VIP, and the SSH connection matches the `SSHServer-Ext` VIP. Note that for the SSH connection, FortiGate also translates the destination port to 22 from 222.

Although not shown on this slide, outgoing connections sourced from the web and SSH server would result in FortiGate using as NAT IP the egress interface address for SNAT, providing there is a matching firewall policy with `nat` enabled.

VIP—Matching Policies

- Default behavior: Firewall address objects match VIPs
 - Blocks an egress-to-ingress connection, when the deny policy precedes the allow policy with the VIP
 - The CLI command `match-vip` is available only for firewall policies with the action set to **DENY**
- VIP policy (WAN to LAN)

Policy	ID	Source	Destination	Schedule	Service	Action
ISP1 (port1) → LAN (port3) ②						
☐ Deny (4)	4	Deny_IP	all	always	ALL	DENY
☐ Allow_Access (3)	3	all	Web_Server	always	HTTP HTTPS	ACCEPT

VIP access falls through to this policy and the connection is blocked

- CLI configuration:

```
config firewall policy
  edit <deny policy ID>
    set match-vip enable
  next
end
```

By default, `match-vip` is enable in the deny policy

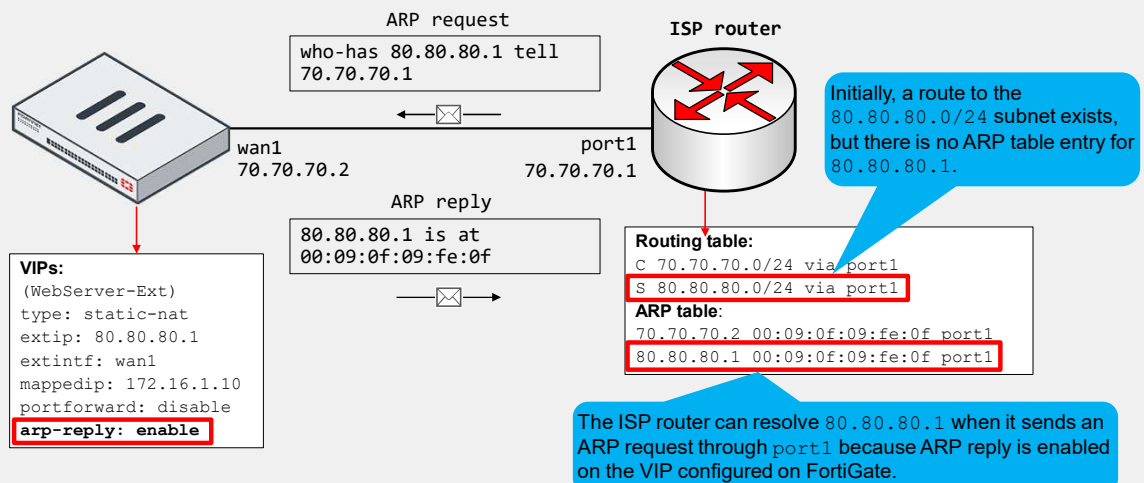
In FortiOS, VIPs and firewall address objects are completely different. They are stored separately with no overlap. Starting in version 7.2.4, the parameter `match-vip` is `enable` by default and allows the firewall address objects to match VIPs.

In the example shown on this slide, the destination of the first firewall policy is set to **all**. This means all destination addresses (0.0.0.0/0), by default, including the external addresses defined on the VIPs. The result is that traffic destined to the external address defined on the **Web_Server** VIP matches the first policy.

But what if you want the first policy to block all incoming traffic to all destinations, except the traffic destined to any VIPs? You can do this by disabling `match-vip` on the first firewall policy. Disabling `match-vip` instructs FortiGate not to also check for VIPs during policy evaluation. Note that the `match-vip` setting is available only when the firewall policy action is set to **DENY**.

ARP Reply Option in VIPs and IP Pools

- Enabled by default; instructs FortiGate to reply to ARP requests for external address
- Sometimes required to overcome routing misconfigurations
 - Example:



When you configure a VIP or an IP pool, ARP reply is enabled by default. When ARP reply is enabled, FortiGate replies to incoming ARP requests for the external address configured in the VIP and IP pools.

Enabling ARP reply is usually not required in most networks because the routing tables on the adjacent devices contain the correct next-hop information, so the networks are reachable. However, sometimes the routing configuration is not fully correct, and having ARP reply enabled can solve the issue for you. For this reason, it's a best practice to keep ARP reply enabled.

Consider the example shown on this slide, which shows an internet connection between FortiGate and an ISP router. The example also shows a simplified version of the ISP router routing table and ARP table.

The ISP assigns the FortiGate administrator the public subnet 80.80.80.0/24 to deploy internet-facing services. The administrator configured the VIP shown on this slide to provide internet users with access to the company web server. While testing, the administrator confirms that internet users can reach the web server at 80.80.80.1.

However, the administrator is likely unaware that having ARP reply enabled was key for a successful connectivity. The reason is that the ISP router doesn't have a route in its routing table to access the 80.80.80.0/24 subnet through the 70.70.70.2 gateway. Instead, the routing table contains a static route for the subnet through port1. The result is that the ISP router generates ARP requests out of port1 to resolve the MAC address of any of the addresses in the 80.80.80.0/24 subnet. Nonetheless, because FortiGate responds to ARP requests for the external address in the VIP, the ISP router is able to resolve the MAC address successfully.

NAT Implementation Best Practices

- Avoid misconfiguring an IP pool range:
 - Double-check the start and end IP addresses of each IP pool
 - Ensure that the IP pool address range does not overlap with addresses assigned to FortiGate and hosts
 - If internal and external users are accessing the same servers, configure your DNS service so internal users resolve to the destination internal address
- Don't configure a NAT rule for inbound traffic unless it is required by an application
- Schedule a maintenance window to make changes on NAT configuration

Use the following best practices when implementing NAT:

- Avoid misconfiguring an IP pool range:
 - Double-check the start and end IP addresses of each IP pool.
 - Ensure that the IP pool address range does not overlap with addresses assigned to FortiGate interfaces or to any hosts on directly connected networks.
 - If you have internal and external users accessing the same servers, configure your DNS services so internal users resolve to use the destination internal address instead of its external address defined in the VIP.
- Don't configure a NAT rule for inbound traffic unless it is required by an application.
 - For example, if there is a matching NAT rule for inbound SMTP traffic, the SMTP server might act as an open relay.
- You must schedule a maintenance window when making changes to NAT settings configuration, since making changes could create a network outage.

Knowledge Check

1. Which criteria does FortiGate use to match traffic to a firewall policy?
 - ✓ A. Source and destination interfaces
 - B. Security profiles

2. What is the purpose of applying security profiles to a firewall policy?
 - A. To allow access to specific subnets
 - ✓ B. To protect your network from threats, and control access to specific applications and URL

3. What is the default IP pool type?
 - A. One-to-one
 - ✓ B. Overload

4. What type is the default VIP type?
 - ✓ A. static-nat
 - B. load-balance

Lesson Progress



Firewall Policies



NAT

Congratulations! You have completed this lesson.

Now, you will review the objectives covered in this lesson.

Review

- ✓ Configure IPv4 firewall policies
- ✓ Monitor traffic logs from firewall policies
- ✓ Choose inspection modes for firewall policies
- ✓ Configure SNAT
- ✓ Configure a firewall policy to perform DNAT using VIP

This slide shows the objectives that you covered in this lesson.

By mastering the objectives covered in this lesson, you learned how to configure, use, and manage firewall policies and NAT on FortiGate.